

**HỌC VIỆN CÔNG NGHỆ BƯU CHÍNH VIỄN THÔNG
KHOA AN TOÀN THÔNG TIN**



**BÁO CÁO BÀI TẬP LỚN
HỌC PHẦN: AN TOÀN HỆ ĐIỀU HÀNH
MÃ HỌC PHẦN: INT1484**

**Đề tài:
TÌM HIỂU VỀ ĐIỆN TOÁN ĐÁM MÂY
VẤN ĐỀ AN NINH AN TOÀN TRONG ĐIỆN TOÁN ĐÁM MÂY.**

Giảng viên hướng dẫn: Phạm Hoàng Duy

Thành viên:	Mã sinh viên
Đinh Việt Hiếu (TN)	B22DCAT116
Nguyễn Đăng Hiếu	B22DCAT120
Lê Xuân Mạnh	B21DCAT125
Nguyễn Văn Quân	B21DCAT157

HỌC KỲ 2 NĂM HỌC 2024-2025

PHÂN CÔNG NHIỆM VỤ NHÓM THỰC HIỆN

TT	Công việc / Nhiệm vụ	SV thực hiện	Thời hạn hoàn thành
1	Tìm hiểu khái quát về Điện toán đám mây; 3 yếu tố; 1 giải pháp.	Đinh Việt Hiếu	5/4/2025
2	Tổng hợp hoàn thành bản báo cáo định dạng Word; 3 yếu tố; 1 giải pháp	Nguyễn Đăng Hiếu	5/4/2025
3	Thiết kế Powerpoint thuyết trình; 3 yếu tố; 1 giải pháp	Lê Xuân Mạnh	5/4/2025
4	Thuyết trình; 3 yếu tố; 1 giải pháp	Nguyễn Văn Quân	5/4/2025

NHÓM THỰC HIỆN TỰ ĐÁNH GIÁ

TT	SV thực hiện	Thái độ tham gia	Mức hoàn thành CV	Kỹ năng giao tiếp	Kỹ năng hợp tác	Kỹ năng lãnh đạo
1	Đinh Việt Hiếu	5	5	4	5	5
2	Nguyễn Đăng Hiếu	5	5	5	5	4
3	Lê Xuân Mạnh	5	5	4	5	4
4	Nguyễn Văn Quân	5	5	4	5	4

Ghi chú:

- Thái độ tham gia: Đánh giá điểm thái độ tham gia công việc chung của nhóm (từ 0: không tham gia, đến 5: chủ động, tích cực).
- Mức hoàn thành CV: Đánh giá điểm mức độ hoàn thành công việc được giao (từ 0: không hoàn thành, đến 5: hoàn thành xuất sắc).
- Kỹ năng giao tiếp: Đánh giá điểm khả năng tương tác, giao tiếp trong nhóm (từ 0: không hoặc giao tiếp rất yếu, đến 5: giao tiếp xuất sắc).
- Kỹ năng hợp tác: Đánh giá điểm khả năng hợp tác, hỗ trợ lẫn nhau, giải quyết mâu thuẫn, xung đột

- Kỹ năng lãnh đạo: Đánh giá điểm khả năng lãnh đạo (từ 0: không có khả năng lãnh đạo, đến 5: có khả năng lãnh đạo tốt, tổ chức và điều phối công việc trong nhóm hiệu quả).

MỤC LỤC

MỤC LỤC	2
CHƯƠNG 1: TỔNG QUAN VỀ ĐIỆN TOÁN Đám Mây	7
1. Điện toán đám mây là gì?	7
2. Kiến trúc điện toán đám mây	8
2.1 Các đặc tính thiết yếu (Essential Characteristics).....	8
2.2 Các mô hình dịch vụ (Service Models)	9
2.3 Mô hình triển khai (Deployment Models)	11
3. Lợi ích và hạn chế của điện toán đám mây.....	11
3.1 Lợi ích.....	11
3.2 Hạn chế.....	12
4. Các công nghệ nền tảng xây dựng điện toán đám mây	12
4.1 Ảo hóa – Virtualization.....	12
4.2 Web 2.0	12
4.3 Lưu trữ phân tán – Distributed Storage.....	13
4.4 Tính toán phân tán – Distributed Computing.....	13
4.5 Điện toán tiện ích – Utility Computing	13
4.6 Băng thông mạng & Độ trễ - Network Bandwidth & Latency.....	13
4.7 Hệ thống chịu lỗi – Fault tolerant system	14
CHƯƠNG 2: MỐI ĐE DỌA AN NINH AN TOÀN CỦA ĐIỆN TOÁN Đám MÂY.....	15
1. Mô tả mối đe dọa.....	15
1.1. Lộ khóa API.	15
1.2. Tấn công chuỗi cung ứng.....	15
1.3. Tái sử dụng mật khẩu.....	15
1.4. Tấn công và đánh cắp dữ liệu.....	15

1.5. Mất dữ liệu do lỗi kỹ thuật.....	16
1.6. Tấn công từ nội bộ.	16
1.7. Rò rỉ dữ liệu từ dịch vụ đám mây.	17
1.8. Đánh cắp tài khoản qua tấn công phishing.	17
1.9. Nhà cung cấp dịch vụ vi phạm quy định bảo vệ dữ liệu.	17
1.10. Tấn công từ chối dịch vụ phân tán.....	17
1.11. Ransomware & Malware.....	18
1.12. Social Engineering.	19
2. Cách thức mối đe dọa ảnh hưởng.	19
2.1. Lộ khóa API	19
2.2. Tấn công chuỗi cung ứng.....	20
2.3. Tái sử dụng mật khẩu	20
2.4. Tấn công và đánh cắp dữ liệu.....	20
2.5. Mất dữ liệu do lỗi kỹ thuật	22
2.6. Tấn công từ nội bộ	23
2.7. Rò rỉ dữ liệu từ dịch vụ đám mây	23
2.8. Đánh cắp tài khoản qua tấn công phishing	24
2.9. Nhà cung cấp dịch vụ vi phạm quy định bảo vệ dữ liệu	25
2.10. Tấn công từ chối dịch vụ phân tán.....	26
2.11. Ransomware & Malware.....	26
2.12. Social Engineering	26
CHƯƠNG 3: TRIỂN KHAI GIẢI PHÁP.....	28
1. Cách thức triển khai.	28
1.1. Giải pháp cho yếu tố “Lộ khóa API”	28
1.2. Giải pháp cho yếu tố “Mất dữ liệu do lỗi kỹ thuật”	28
1.3. Giải pháp cho yếu tố “Rò rỉ dữ liệu từ dịch vụ đám mây”	28
1.4. Giải pháp cho yếu tố “Tấn công từ chối dịch vụ phân tán”	28

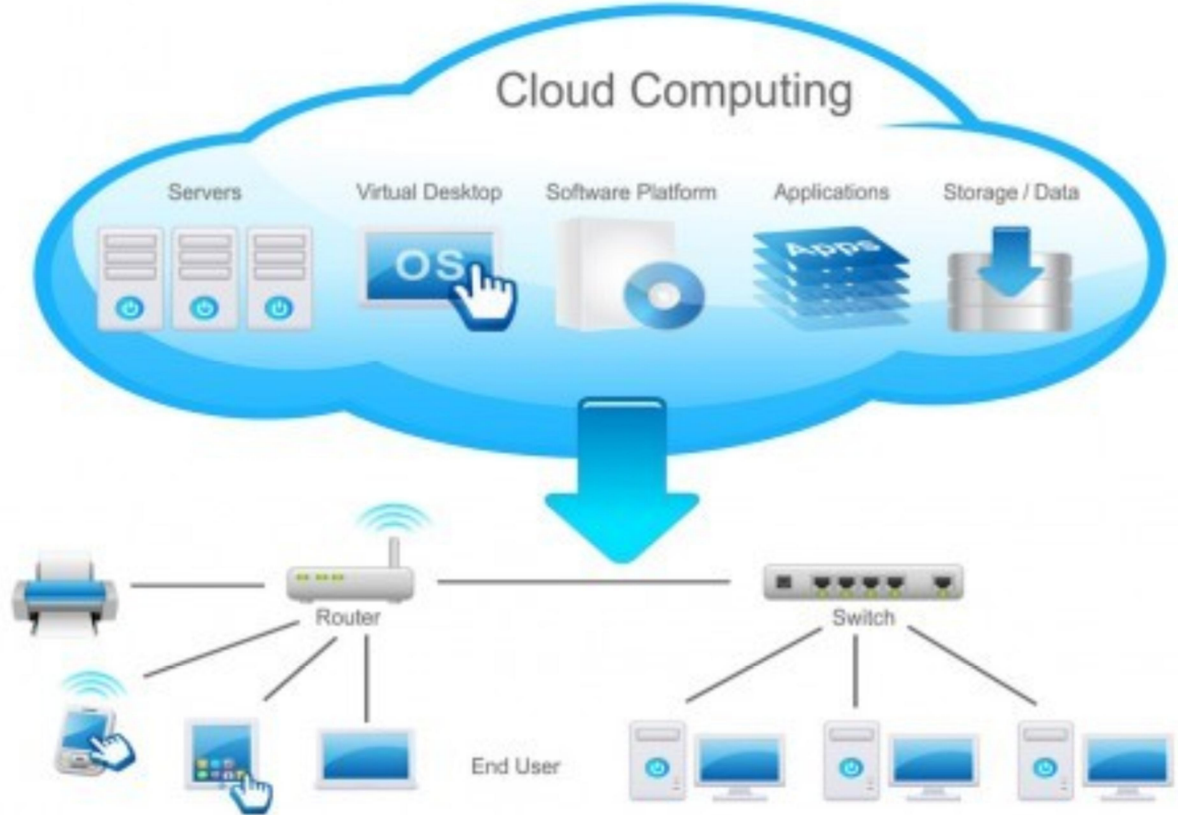
2. Cách thức giải pháp giải quyết mối đe dọa.....	29
2.1. Giải pháp cho yếu tố “Lộ khóa API”	29
2.2. Giải pháp cho yếu tố “Mất dữ liệu do lỗi kỹ thuật”	29
2.3. Giải pháp cho yếu tố “Rò rỉ dữ liệu từ dịch vụ đám mây”	29
2.4. Giải pháp cho yếu tố “Tấn công từ chối dịch vụ phân tán”	30
TÀI LIỆU THAM KHẢO.....	32

CHƯƠNG 1: TỔNG QUAN VỀ ĐIỆN TOÁN ĐÁM MÂY

1. Điện toán đám mây là gì?

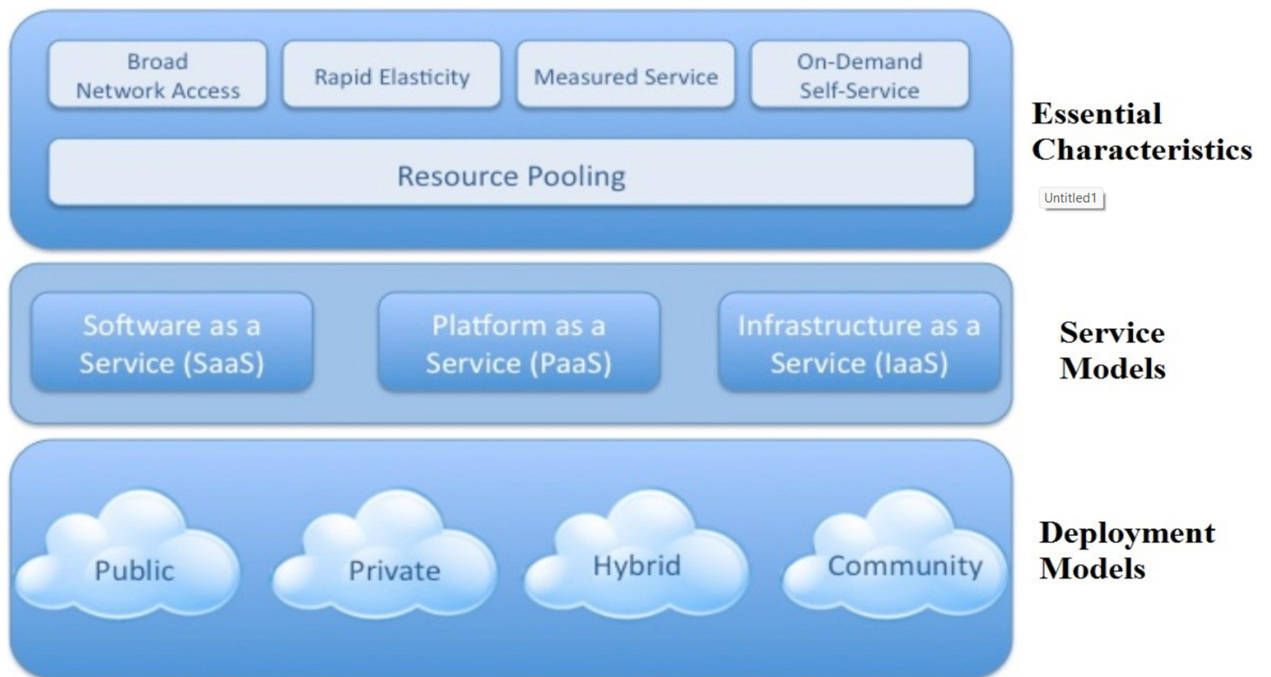
Theo Webopedia.com:

- Điện toán đám mây được định nghĩa là một loại hình điện toán dựa trên việc chia sẻ tài nguyên tính toán thay vì sử dụng các máy chủ cục bộ hoặc thiết bị cá nhân để xử lý các ứng dụng.
- Trong điện toán đám mây, từ "đám mây" được sử dụng như một phép ẩn dụ cho "Internet", vì vậy cụm từ "điện toán đám mây" có nghĩa là "một loại hình điện toán dựa trên Internet", trong đó các dịch vụ khác nhau — chẳng hạn như máy chủ, lưu trữ và ứng dụng — được cung cấp đến máy tính và thiết bị của tổ chức thông qua Internet.



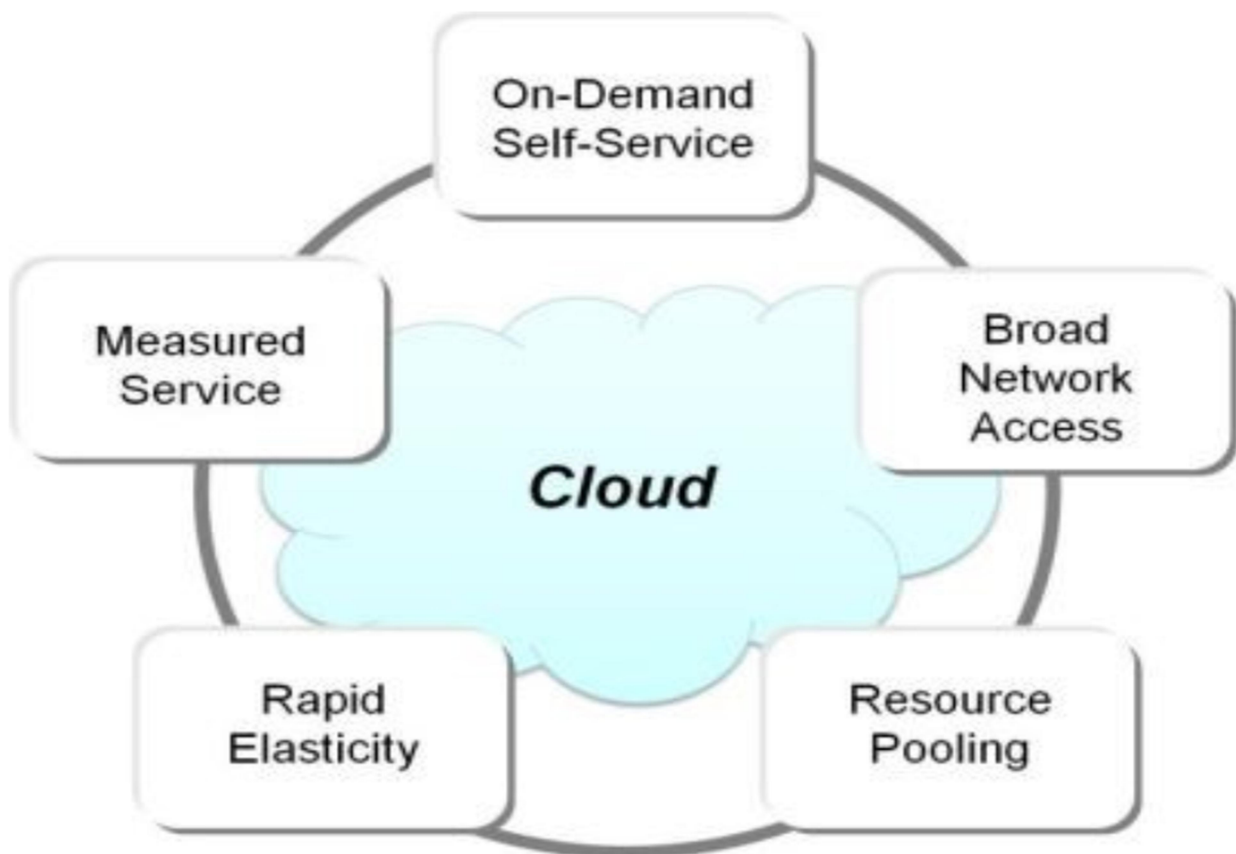
Mô hình điện toán đám mây

2. Kiến trúc điện toán đám mây



Tổng quan kiến trúc ĐTĐM

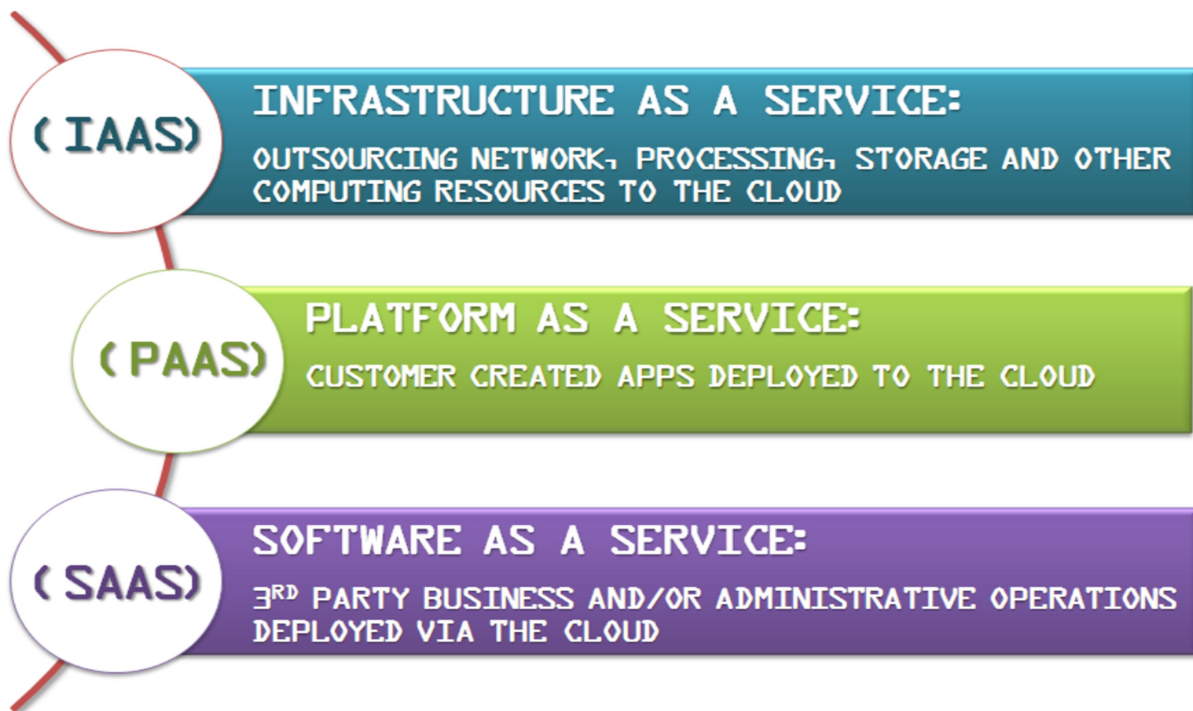
2.1 Các đặc tính thiết yếu (Essential Characteristics)



Các đặc tính thiết yếu của ĐTĐM

- Dịch vụ tự phục vụ theo yêu cầu (On-demand Self-Service)
 - + Người sử dụng có thể cấp phát tài nguyên tính toán như thời gian máy chủ và khả năng lưu trữ một cách tự động mà không cần tương tác trực tiếp với nhà cung cấp dịch vụ.
- Truy cập mạng rộng rãi (Broad Network Access)
 - + Cung cấp khả năng truy nhập đến các tài nguyên tính toán đa dạng, với mọi loại phương tiện truyền dẫn và thiết bị đầu cuối; đảm bảo khả năng truy cập linh hoạt và tiện lợi.
 - + Hỗ trợ nhiều loại mạng: Ethernet, 3G, 4G, wifi,...
 - + Hỗ trợ nhiều thiết bị đầu cuối trên nhiều nền tảng khác nhau: Máy tính, điện thoại di động,...
- Gộp tài nguyên (Resource Pooling)
 - + Tài nguyên máy tính của nhà cung cấp được gộp lại để phục vụ cho nhiều người dùng sử dụng một mô hình đa thuê bao, với các tài nguyên vật lý và ảo khác nhau được cấp phát động và cấp phát lại theo nhu cầu của người dùng.
 - + Việc phân bổ tài nguyên dựa trên nhu cầu sử dụng mà khách hàng không cần biết vị trí chính xác của tài nguyên.
- Co giãn nhanh chóng (Rapid Elasticity)
 - + Các tài nguyên tính toán có thể được cấp phát nhanh chóng và ‘co giãn’ được. Có khả năng tăng hoặc giảm quy mô sử dụng tài nguyên một cách nhanh chóng, tự động theo yêu cầu.
 - + Với người sử dụng, họ có thể đặt mua tài nguyên tính toán với bất kỳ số lượng nào và vào bất kỳ thời gian nào.
- Dịch vụ đo lường được (Measured Service)
 - + Hệ thống điện toán đám mây tự động kiểm soát và tối ưu hóa việc sử dụng tài nguyên bằng cách sử dụng khả năng đo kiểm ở một số mức độ trừu tượng thích hợp cho các loại hình dịch vụ.
 - + Việc sử dụng tài nguyên có thể được giám sát, kiểm soát, và báo cáo – được cung cấp một cách minh bạch cho cả nhà cung cấp và người dùng của các dịch vụ.

2.2 Các mô hình dịch vụ (Service Models)



Các mô hình dịch vụ của ĐTĐM

- IaaS: Infrastructure as a Service – Cơ sở hạ tầng như một dịch vụ
Khách hàng có thể thuê kết nối mạng, năng lực xử lý, lưu trữ và các tài nguyên tính toán khác trên đám mây:
 - + Có khả năng cung cấp cho khách hàng các tài nguyên tính toán như năng lực xử lý, lưu trữ, mạng và các tài nguyên khác.
 - + Khách hàng có thể triển khai và chạy các phần mềm tùy ý, bao gồm cả hệ điều hành và các ứng dụng.
 - + Khách hàng không được quản lý hoặc điều khiển hạ tầng đám mây, nhưng có khả năng điều khiển hệ điều hành, tiện ích lưu trữ, các ứng dụng đã cài đặt và có thể điều khiển một phần các thành phần mạng (như tường lửa cho host).
- PaaS: Platform as a Service – Nền tảng như một dịch vụ
Khách hàng có thể tạo các ứng dụng và triển khai lên đám mây:
 - + Khách hàng được cung cấp khả năng triển khai các ứng dụng trên nền tảng đám mây đã mua/thuê sử dụng các ngôn ngữ lập trình và công cụ do nhà cung cấp dịch vụ hỗ trợ.
 - + Khách hàng không được quản lý hoặc điều khiển hạ tầng đám mây, bao gồm mạng, máy chủ, hệ điều hành, khả năng lưu trữ, nhưng có thể điều khiển các ứng dụng đã triển khai, và có thể cả việc cấu hình môi trường hoạt động cho các ứng dụng.
- SaaS: Software as a Service – Phần mềm như một dịch vụ

- + Khách hàng có thể thuê sử dụng các ứng dụng của nhà cung cấp triển khai trên hạ tầng đám mây.
- + Các ứng dụng có thể được truy nhập từ nhiều máy khách khác nhau thông qua một giao diện máy khách ‘gây’ (thin client), như là 1 trình duyệt (VD: 1 web-based email).
- + Khách hàng không được quản lý hoặc điều khiển hạ tầng đám mây, bao gồm mạng, máy chủ, hệ điều hành, khả năng lưu trữ, hoặc thậm chí tính năng của từng ứng dụng. Tuy nhiên, họ có thể điều khiển hạn chế các cài đặt cấu hình ứng dụng của người dùng.

2.3 Mô hình triển khai (Deployment Models)

- Đám mây riêng (Private Cloud)
 - + Hạ tầng đám mây được vận hành chỉ cho một tổ chức duy nhất.
 - + Có thể được quản lý bởi tổ chức đó hoặc 1 bên thứ 3.
 - + Có thể được host tại chỗ hoặc ở bên ngoài.
- Đám mây cộng đồng (Community Cloud)
 - + Hạ tầng đám mây được chia sẻ bởi nhiều tổ chức.
 - + Hỗ trợ một cộng đồng có cùng các mối quan tâm (như sứ mệnh, yêu cầu an ninh, chính sách, ...).
 - + Có thể được quản lý bởi các tổ chức đó hoặc 1 bên thứ 3.
 - + Có thể được host tại chỗ hoặc ở bên ngoài.
- Đám mây công cộng (Public Cloud)
 - + Hạ tầng đám mây được cung cấp rộng rãi cho công chúng, hoặc một tập đoàn công nghiệp lớn.
 - + Sở hữu bởi một tổ chức cung cấp dịch vụ điện toán đám mây.
- Đám mây lai (Hybrid Cloud)
 - + Hạ tầng đám mây là sự kết hợp của 2 hay nhiều đám mây (đám mây riêng, công cộng, hoặc cộng đồng).
 - + Các đám mây thành viên vẫn là các thực thể riêng, nhưng được liên kết thông qua công nghệ chuẩn hoặc độc quyền, cho phép dữ liệu và ứng dụng khả chuyển (ví dụ: Bùng nổ đám mây (Cloud Bursting) cho cân bằng tải giữa các đám mây).

3. Lợi ích và hạn chế của điện toán đám mây

3.1 Lợi ích

- Location independence: Tài nguyên tính toán được cung cấp độc lập về vị trí (mọi lúc, mọi nơi).
- Low total cost of ownership: Tổng chi phí sở hữu rẻ.
- Support: Hỗ trợ tốt.

- Secure and storage management: Khả năng quản lý lưu trữ và bảo mật.
- Scalability and sustainability: Khả năng mở rộng và bền vững.
- Highly automated: Tự động hóa cao (người dùng có thể đăng ký sử dụng tài nguyên hoàn toàn tự động).
- Maintenance: Bảo trì tốt.

3.2 Hạn chế

- Internet required: Luôn yêu cầu phải có kết nối Internet.
- Slow Internet connection inefficiency: Làm việc không hiệu quả với kết nối Internet tốc độ chậm.
- Feature limitations: Có thể có hạn chế về tính năng.
- Low performances: Hiệu năng có thể thấp.
- Unsecured stored data: Dữ liệu lưu trữ có thể không an toàn.
- Cloud interoperability issues: Vấn đề tương thích giữa các đám mây.

4. Các công nghệ nền tảng xây dựng điện toán đám mây

4.1 Ảo hóa – Virtualization

Ảo hóa là công nghệ quan trọng giúp xây dựng hạ tầng điện toán đám mây. Nó cho phép chạy nhiều hệ điều hành và ứng dụng trên cùng một máy chủ vật lý bằng cách tạo ra các máy ảo.

- Ảo hóa cho phép chia sẻ các tài nguyên tính toán: máy chủ, dữ liệu, mạng, phần mềm và CSDL.
- Tăng hiệu suất sử dụng tài nguyên, giảm chi phí phần cứng và hỗ trợ triển khai linh hoạt.
- Giúp dễ dàng di chuyển, mở rộng hoặc sao lưu hệ thống mà không cần thay đổi phần cứng thực tế.
- Công nghệ phổ biến: VMware, KVM, Hyper-V, Xen.

4.2 Web 2.0

Web 2.0 là thế hệ thứ hai của công nghệ web, giúp cải thiện khả năng tương tác, chia sẻ nội dung và hợp tác trên nền tảng trực tuyến. Công nghệ Web 2.0 đóng vai trò quan trọng trong điện toán đám mây bằng cách cung cấp các ứng dụng và dịch vụ dựa trên trình duyệt mà không cần cài đặt phần mềm trên máy tính cá nhân

- Web 2.0 cung cấp giao diện thân thiện, hỗ trợ các ứng dụng web động, tương tác và mạng xã hội.
- Đóng vai trò quan trọng trong SaaS (Software as a Service), giúp người dùng truy cập và sử dụng ứng dụng trên nền web mà không cần cài đặt.

- Công nghệ phổ biến: AJAX, JavaScript, HTML5, RESTful APIs.

4.3 Lưu trữ phân tán – Distributed Storage

Lưu trữ phân tán (Distributed Storage) là một hệ thống lưu trữ trong đó dữ liệu không được lưu trữ trên một máy chủ duy nhất mà được chia nhỏ và phân tán trên nhiều máy chủ khác nhau. Điều này giúp tăng độ tin cậy, bảo mật, khả năng mở rộng và hiệu suất truy xuất dữ liệu.

- Lưu trữ dữ liệu trên nhiều máy chủ hoặc trung tâm dữ liệu để đảm bảo tính khả dụng cao (High Availability) và khả năng mở rộng.
- Giúp bảo vệ dữ liệu khỏi sự cố phần cứng, hỗ trợ khôi phục sau thảm họa.
- Công nghệ phổ biến: HDFS (Hadoop Distributed File System), Ceph, Google File System (GFS), Amazon S3.

4.4 Tính toán phân tán – Distributed Computing

Tính toán phân tán (Distributed Computing) là mô hình tính toán trong đó nhiều máy tính hoạt động cùng nhau như một hệ thống duy nhất để giải quyết các bài toán phức tạp. Dữ liệu và quá trình xử lý không tập trung vào một máy chủ duy nhất mà được chia nhỏ và phân tán trên nhiều thiết bị, giúp tăng tốc độ xử lý, khả năng mở rộng và độ tin cậy.

- Chia nhỏ tác vụ và xử lý trên nhiều máy tính/máy chủ khác nhau để tăng hiệu suất.
- Giúp chạy các ứng dụng lớn, AI, Big Data, mô phỏng khoa học trên hạ tầng đám mây.
- Công nghệ phổ biến: Apache Hadoop, Apache Spark, Kubernetes, Google MapReduce.

4.5 Điện toán tiện ích – Utility Computing

Utility Computing (Điện toán tiện ích) là một mô hình dịch vụ nhằm cung cấp các tài nguyên tính toán, như phần cứng, phần mềm và băng thông mạng cho khách hàng khi họ có yêu cầu

- Khách hàng chỉ phải thanh toán phí dịch vụ theo lượng sử dụng (pay as you go) mà không phải trả khoản phí cố định, hoặc mức giá cố định.
- Điện toán tiện ích là một tập hợp con của điện toán đám mây, cho phép người dùng mở rộng quy mô dựa trên nhu cầu của họ
- Công nghệ phổ biến: Amazon EC2, Microsoft Azure, Google Cloud Compute Engine.

4.6 Băng thông mạng & Độ trễ - Network Bandwidth & Latency

Băng thông mạng là khả năng truyền tải dữ liệu qua kết nối mạng trong một khoảng thời gian nhất định, thường được đo bằng megabit mỗi giây (Mbps) hoặc gigabit mỗi giây (Gbps).

- Đảm bảo kết nối tốc độ cao giữa người dùng, máy chủ và trung tâm dữ liệu.
- Giúp cải thiện truy cập nhanh, truyền dữ liệu ổn định, giảm độ trễ khi chạy ứng dụng đám mây.
- Công nghệ phổ biến: CDN (Content Delivery Network), SDN (Software-Defined Networking), 5G, Edge Computing.

4.7 Hệ thống chịu lỗi – Fault tolerant system

- Đảm bảo kết nối tốc độ cao giữa người dùng, máy chủ và trung tâm dữ liệu
- Giúp cải thiện truy cập nhanh, truyền dữ liệu ổn định, giảm độ trễ khi chạy ứng dụng đám mây.
- Công nghệ phổ biến: CDN (Content Delivery Network), SDN (Software-Defined Networking), 5G, Edge Computing.

CHƯƠNG 2: MỐI ĐE DỌA AN NINH AN TOÀN CỦA ĐIỆN TOÁN Đám MÂY

1. Mô tả mối đe dọa.

1.1. Lộ khóa API.

- Khóa API là một chuỗi gồm chữ và số được nhà phát triển API sử dụng để kiểm soát quyền truy cập vào API. API là cơ chế giao tiếp cho phép hai mô-đun phần mềm trao đổi dữ liệu. Khi tạo API cho mô-đun, các nhà phát triển ứng dụng khác có thể gọi API đó để tích hợp chức năng trong mô-đun vào mã của họ.
- Lộ khóa API xảy ra khi khóa API bị tiết lộ hoặc công khai mà không được bảo vệ. Điều này có thể dẫn đến các rủi ro bảo mật nghiêm trọng, như việc kẻ xấu lợi dụng khóa API để truy cập trái phép, gây thiệt hại tài nguyên hoặc lạm dụng dịch vụ để thực hiện các hoạt động không hợp pháp.
- Một số nguyên nhân:
 - + Lưu trữ khóa API trong mã nguồn công khai.
 - + Không mã hóa khóa API khi lưu trữ.
 - + Chia sẻ qua các ứng dụng không an toàn (email, tin nhắn không được mã hóa).

1.2. Tấn công chuỗi cung ứng.

- Tấn công chuỗi cung ứng là một hình thức tấn công mạng nhắm vào các thành phần, nhà cung cấp bên thứ ba, hoặc quy trình mà nhà cung cấp dịch vụ đám mây hoặc khách hàng của họ sử dụng để xây dựng, triển khai và vận hành các dịch vụ và ứng dụng trên nền tảng đám mây. Thay vì tấn công trực tiếp vào mục tiêu cuối cùng, kẻ tấn công xâm nhập vào một mắt xích yếu hơn trong chuỗi cung ứng, sau đó sử dụng điểm xâm nhập này để tiếp cận và gây hại cho mục tiêu chính.

1.3. Tái sử dụng mật khẩu.

- Tái sử dụng mật khẩu là một lỗ hổng bảo mật nghiêm trọng phát sinh khi người dùng sử dụng cùng một mật khẩu cho nhiều tài khoản khác nhau, bao gồm cả tài khoản dịch vụ điện toán đám mây và các tài khoản trực tuyến khác.

1.4. Tấn công và đánh cắp dữ liệu.

- Tấn công và đánh cắp dữ liệu trong Điện toán đám mây được định nghĩa là hành động truy cập trái phép vào dữ liệu được lưu trữ hoặc xử

lý trên môi trường đám mây, dẫn đến việc sao chép, tiết lộ, sửa đổi, xóa hoặc sử dụng dữ liệu đó mà không có sự cho phép của chủ sở hữu.

- Vào năm 2021, Microsoft Azure gặp sự cố khi lỗi hỏng bảo mật OMIGOD trong phần mềm Open Management Infrastructure (OMI) bị khai thác. Lỗi hỏng này cho phép kẻ tấn công thực thi mã từ xa trên các máy ảo Linux, làm gián đoạn dịch vụ và tiềm ẩn nguy cơ rò rỉ dữ liệu. Mặc dù Microsoft đã phát hành bản vá, nhưng sự cố này làm lộ rõ mối nguy hại từ việc không giám sát kỹ lưỡng các dịch vụ đám mây.

1.5. Mất dữ liệu do lỗi kỹ thuật.

- Mất dữ liệu do lỗi kỹ thuật trong điện toán đám mây (Data Loss due to Technical Errors in Cloud Computing) được định nghĩa là tình trạng dữ liệu được lưu trữ hoặc xử lý trên môi trường đám mây bị hư hỏng, không thể truy cập được, hoặc bị xóa vĩnh viễn do các vấn đề phát sinh từ hệ thống kỹ thuật của nhà cung cấp dịch vụ đám mây hoặc do chính người dùng trong quá trình thao tác.
- Vào tháng 2 năm 2017, GitLab gặp phải sự cố nghiêm trọng khi một nhân viên vô tình xóa cơ sở dữ liệu sản xuất trong quá trình sao lưu và phục hồi hệ thống. Kết quả là hàng nghìn kho lưu trữ mã nguồn của người dùng bị mất. Do không có sao lưu đầy đủ, quá trình khôi phục gặp khó khăn và gây gián đoạn dịch vụ trong nhiều giờ. Mặc dù sự cố được khắc phục nhanh chóng, nhưng nó đã gây tổn hại nghiêm trọng đến uy tín của GitLab và là một bài học về việc duy trì sao lưu và kiểm tra phục hồi định kỳ.

1.6. Tấn công từ nội bộ.

- Tấn công từ nội bộ (Insider Threat) trong điện toán đám mây được định nghĩa là hành động cố ý hoặc vô ý của một cá nhân có quyền truy cập hợp pháp vào hệ thống và dữ liệu trong môi trường điện toán đám mây, gây ra các tác động tiêu cực như làm lộ, sửa đổi, phá hủy hoặc đánh cắp dữ liệu, hoặc làm gián đoạn hoạt động của dịch vụ.
- Vào năm 2013, Edward Snowden, cựu nhân viên của NSA, đã tiết lộ thông tin mật về các chương trình giám sát toàn cầu mà cơ quan này thực hiện, bao gồm chương trình PRISM, cho phép NSA thu thập dữ liệu từ các công ty công nghệ lớn như Google và Facebook. Những tiết lộ này gây ra tranh cãi toàn cầu về quyền riêng tư và giám sát của chính phủ. Snowden phải trốn sang Nga để tránh bị truy tố, trong khi vụ rò rỉ này đẩy lên các cuộc thảo luận về sự cân bằng giữa an ninh quốc gia và quyền riêng tư cá nhân.

1.7. Rò rỉ dữ liệu từ dịch vụ đám mây.

- Rò rỉ dữ liệu từ dịch vụ đám mây (Data Leakage from Cloud Services) trong điện toán đám mây được định nghĩa là tình trạng dữ liệu nhạy cảm hoặc bí mật được lưu trữ hoặc xử lý trên môi trường đám mây bị tiết lộ cho những cá nhân, tổ chức hoặc hệ thống không có quyền truy cập.
- Vụ rò rỉ dữ liệu của Capital One năm 2019 là một trong những vi phạm dữ liệu lớn nhất trong lịch sử tài chính, ảnh hưởng đến thông tin cá nhân của hơn 100 triệu khách hàng. Hacker đã khai thác lỗ hổng trong hệ thống tường lửa của Amazon Web Services (AWS) và sử dụng kỹ thuật Server-Side Request Forgery (SSRF) để truy cập trái phép vào dữ liệu nhạy cảm.

1.8. Đánh cắp tài khoản qua tấn công phishing.

- Đánh cắp tài khoản qua tấn công phishing trong điện toán đám mây (Account Hijacking via Phishing Attacks in Cloud Computing) được định nghĩa là hành động lừa đảo người dùng dịch vụ đám mây tiết lộ thông tin đăng nhập (tên người dùng và mật khẩu) hoặc các thông tin nhạy cảm khác thông qua các kỹ thuật giả mạo, từ đó kẻ tấn công có thể truy cập trái phép và chiếm quyền kiểm soát tài khoản của nạn nhân trên nền tảng đám mây.
- Cuộc tấn công Google Docs Phishing Attack vào năm 2017 đã khai thác sự tin tưởng của người dùng đối với dịch vụ Google bằng cách gửi email giả mạo từ Google Docs. Email này chứa một liên kết độc hại, khi người dùng nhấp vào và cấp quyền truy cập, hacker có thể kiểm soát toàn bộ tài khoản Google của họ.

1.9. Nhà cung cấp dịch vụ vi phạm quy định bảo vệ dữ liệu.

- Nhà cung cấp dịch vụ vi phạm quy định bảo vệ dữ liệu trong điện toán đám mây (Cloud Service Provider Data Protection Regulation Violation) được định nghĩa là tình trạng nhà cung cấp dịch vụ điện toán đám mây không tuân thủ các luật, quy định, tiêu chuẩn, hoặc các điều khoản hợp đồng liên quan đến việc thu thập, lưu trữ, xử lý, và bảo vệ dữ liệu cá nhân hoặc dữ liệu nhạy cảm của khách hàng được lưu trữ hoặc xử lý trên nền tảng của họ.
- Google bị phạt 50 triệu euro vì không cung cấp đủ minh bạch về cách thu thập và sử dụng dữ liệu người dùng theo quy định GDPR. Việc không có thông tin rõ ràng đã vi phạm quyền riêng tư của người dùng.

1.10. Tấn công từ chối dịch vụ phân tán.

- Tấn công DDoS nhằm vào việc làm cạn kiệt tài nguyên của hệ thống thông qua việc gửi một lượng lớn dữ liệu đến máy chủ đích. Từ góc độ hệ điều hành, DDoS chủ yếu khai thác điểm yếu trong stack mạng của OS, gây ra các vấn đề như nghẽn băng thông và tài nguyên.
- SYN Flood và Cạn Kiệt Bảng Kết Nối: Các cuộc tấn công SYN Flood làm đầy bảng kết nối TCP/IP của hệ điều hành, khiến OS không thể xử lý các kết nối hợp pháp. Các tham số mạng như backlog, time_wait, và bộ đệm cần phải được tối ưu để đảm bảo hệ thống có thể xử lý lượng kết nối lớn mà không bị quá tải.
- Làm Giảm Hiệu Suất Của Tiến Trình Nền: DDoS không chỉ làm nghẽn mạng mà còn có thể làm giảm hiệu suất của các tiến trình nền (background processes) của hệ điều hành, gây ra tình trạng nghẽn tài nguyên như bộ nhớ và CPU.

1.11. Ransomware & Malware.

- Ransomware và malware là hai loại phần mềm độc hại có khả năng gây ra những thiệt hại nghiêm trọng cho hệ thống điện toán đám mây. Các cuộc tấn công này không chỉ ảnh hưởng đến ứng dụng mà còn có thể làm thay đổi các thành phần cơ bản của hệ điều hành, khiến toàn bộ hệ thống bị tổn thương.
- Khai thác lỗ hổng trong nhân hệ điều hành (Kernel Exploitation): Ransomware thường khai thác các lỗ hổng trong kernel của hệ điều hành. Việc khai thác lỗ hổng kernel cho phép kẻ tấn công có quyền truy cập vào hệ thống với quyền cao nhất (root/administrator). Điều này cho phép malware kiểm soát toàn bộ hệ thống, thay đổi các cấu hình bảo mật, vô hiệu hóa các dịch vụ bảo vệ như tường lửa, hoặc thậm chí xóa các log của hệ thống để che giấu hành động của mình.
- Thao túng hệ thống tập tin và mã hóa dữ liệu: Malware có thể truy cập và thay đổi các tệp hệ thống cũng như mã hóa dữ liệu của người dùng. Các API của hệ điều hành cho phép malware thao túng hệ thống tập tin, khiến dữ liệu trở nên không thể truy cập được nếu không có khóa giải mã. Điều này đặc biệt nguy hiểm trong môi trường đám mây, nơi dữ liệu có thể được chia sẻ giữa nhiều người dùng và không có sự bảo vệ đầy đủ.
- Chiếm dụng tài nguyên hệ thống (Resource Hijacking): Malware có thể chiếm dụng tài nguyên hệ thống như CPU, bộ nhớ, và băng thông mạng. Các tiến trình độc hại này thường được ẩn mình trong hệ điều hành, làm chậm các tiến trình hợp pháp và gây ra tình trạng "resource

starvation", ảnh hưởng đến hiệu suất và tính ổn định của các dịch vụ đám mây.

1.12. Social Engineering.

- Social Engineering khai thác yếu điểm của con người để đánh lừa nạn nhân cung cấp thông tin đăng nhập hoặc thực hiện hành động có lợi cho kẻ tấn công. Mặc dù không phải là tấn công kỹ thuật trực tiếp vào hệ điều hành, nhưng hậu quả của nó có thể rất nghiêm trọng.
- Chiếm quyền truy cập hệ thống thông qua thông tin đăng nhập: Nếu kẻ tấn công có thể đánh lừa nhân viên quản trị hệ thống cung cấp thông tin đăng nhập hoặc các quyền truy cập cao, họ có thể thay đổi cấu hình bảo mật, vô hiệu hóa các dịch vụ giám sát và truy cập trái phép vào hệ thống.
- Thay đổi cấu hình bảo mật hệ điều hành: Sau khi có quyền truy cập, kẻ tấn công có thể thay đổi các chính sách bảo mật của hệ điều hành, như vô hiệu hóa UAC (User Account Control) trên Windows hoặc cấu hình sudo trên Linux, tạo cơ hội cho các cuộc tấn công sau này.

2. Cách thức mối đe dọa ảnh hưởng.

2.1. Lộ khóa API

- Tấn công vét cạn và tấn công từ chối dịch vụ phân tán:
 - + Khi một khóa API bị lộ, kẻ tấn công có thể lợi dụng nó để gửi lượng lớn yêu cầu đến hệ thống mục tiêu, gây quá tải và làm gián đoạn dịch vụ.
 - + Ví dụ tấn công DDoS nhắm vào nền tảng giao tiếp Twilio: một tổ chức đã vô tình làm rò rỉ khóa API Twilio. Kẻ tấn công đã sử dụng khóa này để gửi hàng triệu tin nhắn SMS giả mạo đến nhiều người dùng khác nhau. Hậu quả là hệ thống Twilio bị quá tải do lượng lớn yêu cầu không hợp lệ; danh tiếng bị ảnh hưởng nghiêm trọng; chi phí vận hành tăng mạnh do lượng tin nhắn vượt mức quy định.
- Sử dụng trái phép:
 - + Vào năm 2018, một sự cố đã xảy ra khi khóa API của Uber bị lộ trên Github, dẫn đến việc kẻ xấu sử dụng khóa này để truy cập vào hệ thống của công ty nơi chứa dữ liệu nhạy cảm của khách hàng và tài xế.
- Tăng chi phí không mong muốn:
 - + Một nhóm hacker đã tìm thấy một dự án mã nguồn mở trên GitHub chứa thông tin xác thực cho Google Cloud Platform (GCP). Chúng nhanh chóng triển khai nhiều phiên bản máy chủ

GPU trên GCP để đào đồng Monero (XMR). Hậu quả là chủ sở hữu GCP nhận hóa đơn hơn 45000USD chỉ trong 2 tuần.

- Mất dữ liệu nhạy cảm:
 - + Cambridge Analytica và Facebook (2016-2018): API của Facebook cho phép ứng dụng truy cập dữ liệu người dùng đã bị lạm dụng bởi Cambridge Analytica. Điều này dẫn đến việc thu thập thông tin của hàng triệu người dùng Facebook mà không có sự đồng ý của họ. Sự cố này làm dấy lên mối quan ngại lớn về quyền riêng tư và cách bảo vệ dữ liệu.

2.2. Tấn công chuỗi cung ứng

- Xâm nhập vào một nhà cung cấp yếu hơn: Kẻ tấn công xác định một nhà cung cấp bên thứ ba có biện pháp bảo mật lỏng lẻo hơn mục tiêu chính.
- Gây tổn hại cho nhà cung cấp: Kẻ tấn công có thể cài đặt phần mềm độc hại, đánh cắp thông tin đăng nhập, hoặc tạo backdoor trong hệ thống của nhà cung cấp.
- Lan rộng sang mục tiêu chính: Thông qua kết nối hoặc sự phụ thuộc của mục tiêu chính vào nhà cung cấp bị xâm nhập, kẻ tấn công có thể tiếp cận và gây hại cho hệ thống đám mây hoặc dữ liệu của mục tiêu.

2.3. Tái sử dụng mật khẩu

- Rò rỉ mật khẩu từ một dịch vụ khác: Một trong những trang web hoặc dịch vụ trực tuyến mà người dùng sử dụng (không nhất thiết phải là dịch vụ đám mây) có thể bị tấn công và cơ sở dữ liệu chứa thông tin tài khoản (bao gồm cả mật khẩu) bị rò rỉ.
- Kẻ tấn công thu thập thông tin: Kẻ tấn công thu thập danh sách tên người dùng và mật khẩu bị rò rỉ này.
- Thử nghiệm trên dịch vụ đám mây: Kẻ tấn công sau đó sẽ thử sử dụng các cặp tên người dùng và mật khẩu này để đăng nhập vào tài khoản dịch vụ điện toán đám mây của người dùng đó. Nếu người dùng đã tái sử dụng mật khẩu, kẻ tấn công sẽ có khả năng truy cập trái phép vào tài khoản đám mây thành công.

2.4. Tấn công và đánh cắp dữ liệu

- Với người dùng:
 - + Rủi ro mất dữ liệu và bảo mật: Kẻ tấn công có thể truy cập và đánh cắp dữ liệu nhạy cảm của người dùng, từ đó gây nguy cơ rò rỉ thông tin, bao gồm dữ liệu khách hàng, tài liệu nội bộ và mã

nguồn. Điều này có thể dẫn đến các vi phạm bảo mật nghiêm trọng và ảnh hưởng đến uy tín của doanh nghiệp

- + Tăng nguy cơ tấn công phụ trợ: Sau khi xâm nhập vào hệ thống, kẻ tấn công có thể di chuyển ngang trong hệ thống Azure, tấn công các tài nguyên khác hoặc hệ thống của khách hàng. Điều này tăng rủi ro cho chuỗi cung ứng và có thể làm ảnh hưởng đến nhiều doanh nghiệp và hệ thống phụ thuộc vào Azure.

- Với Microsoft Azure:

- + Mất uy tín và niềm tin: Khi lỗ hổng bảo mật như OMIGOD bị khai thác, Microsoft Azure mất niềm tin từ khách hàng. Các tổ chức và doanh nghiệp phụ thuộc vào bảo mật của Azure có thể chuyển sang các dịch vụ khác, dẫn đến mất khách hàng và giảm sự phát triển của nền tảng.
- + Chi phí khắc phục sự cố: Microsoft phải đầu tư chi phí lớn để vá lỗ hổng bảo mật và bảo vệ các dịch vụ Azure. Các biện pháp nâng cao bảo mật, bao gồm phát hành bản vá và cải thiện quy trình kiểm tra, sẽ tốn kém và yêu cầu nhiều tài nguyên.
- + Khả năng bị phạt: Nếu sự cố dẫn đến vi phạm các quy định bảo mật dữ liệu (như GDPR hoặc HIPAA), Microsoft có thể phải đối mặt với hình phạt tài chính. Điều này không chỉ ảnh hưởng đến tài chính của công ty mà còn gây tổn hại đến danh tiếng của Azure trong ngành.

- Hậu quả:

- + Rò rỉ đánh cắp dữ liệu
 - Sau khi chiếm được hệ thống, kẻ tấn công có thể truy cập vào các tệp nhạy cảm, thông tin đăng nhập, cơ sở dữ liệu và tài liệu nội bộ.
 - Gây ảnh hưởng đến bảo mật dữ liệu khách hàng, dẫn đến vi phạm các tiêu chuẩn như GDPR, HIPAA nếu doanh nghiệp bị tấn công.
- + Lây lan trong hệ thống nội bộ (lateral movement)
 - Sau khi chiếm một máy chủ, kẻ tấn công có thể di chuyển sang các hệ thống khác trong cùng mạng Azure, mở rộng quy mô tấn công.
 - Gây ra mất an toàn toàn bộ hạ tầng đám mây của doanh nghiệp.
- + Lỗ hổng chưa được vá dẫn đến nhiều hệ thống bị tấn công

- Sau khi lỗ hổng OMIGOD được phát hiện, nhiều máy ảo Linux trên Azure đã trở thành mục tiêu tấn công. Các tổ chức chưa kịp cập nhật bản vá đã bị kẻ tấn công khai thác thành công lỗ hổng để thực thi mã từ xa.
- Vì không có cảnh báo rõ ràng về sự tồn tại của OMI, một số doanh nghiệp không kịp phát hiện và khắc phục.

2.5. Mất dữ liệu do lỗi kỹ thuật

- Với người dùng:
 - + Mất mát dữ liệu: Các người dùng bị ảnh hưởng bởi sự cố này mất hoàn toàn các kho lưu trữ mã nguồn, ảnh hưởng đến công việc phát triển của họ. Những dự án quan trọng có thể bị gián đoạn, làm giảm năng suất và kéo dài thời gian hoàn thành.
 - + Khó khôi phục: Do không có sao lưu đầy đủ, người dùng không thể phục hồi dữ liệu ngay lập tức. Một số dự án có thể bị mất vĩnh viễn nếu người dùng không có bản sao lưu ngoài GitLab.
- Với GitLab:
 - + Tổn hại uy tín: Sự cố xóa dữ liệu khiến GitLab mất niềm tin từ người dùng và khách hàng. Điều này có thể dẫn đến mất khách hàng và ảnh hưởng đến khả năng giữ chân khách hàng lâu dài, đặc biệt là các doanh nghiệp lớn và tổ chức yêu cầu bảo mật cao.
 - + Chi phí khắc phục sự cố: GitLab phải chi tiêu một lượng lớn tiền để khôi phục dữ liệu và cải thiện các biện pháp bảo mật để ngăn ngừa sự cố tương tự xảy ra trong tương lai. Việc này cũng ảnh hưởng đến tài chính và nguồn lực của công ty.
 - + Gián đoạn dịch vụ: GitLab không thể cung cấp dịch vụ ổn định trong khoảng thời gian sự cố xảy ra, ảnh hưởng đến hoạt động bình thường của nền tảng và làm giảm chất lượng dịch vụ. Điều này gây ra mất lòng tin trong cộng đồng người dùng và khách hàng doanh nghiệp.
- Hậu quả:
 - + Mất dữ liệu quan trọng:
 - Hàng nghìn kho lưu trữ mã nguồn của người dùng bị xóa hoàn toàn khi cơ sở dữ liệu sản xuất bị xóa nhầm.
 - Dữ liệu không thể phục hồi ngay lập tức, ảnh hưởng đến các dự án quan trọng của người dùng.
 - + Gián đoạn dịch vụ dài:

- Sự cố làm gián đoạn dịch vụ trong nhiều giờ, khiến người dùng không thể truy cập hoặc làm việc với mã nguồn của mình.
- Tạo ra khó khăn cho các đội phát triển, dẫn đến mất thời gian và năng suất làm việc.
- + **Tổn hại uy tín:**
 - Sự cố làm giảm niềm tin của người dùng vào khả năng quản lý và bảo vệ dữ liệu của GitLab.
 - Khách hàng lớn và các công ty phụ thuộc vào GitLab bị ảnh hưởng nghiêm trọng, gây mất uy tín cho dịch vụ.

2.6. Tấn công từ nội bộ

- **Rủi ro lộ thông tin nhạy cảm:** Các dữ liệu cá nhân và nhạy cảm của người dùng, như thông tin tài chính, mật khẩu, hoặc hoạt động tìm kiếm, có thể bị thu thập mà không được bảo mật. Điều này tạo ra nguy cơ bị lạm dụng hoặc tấn công mạng.
- **Mất niềm tin vào dịch vụ trực tuyến:** Sự việc làm mất lòng tin của người dùng vào các dịch vụ trực tuyến và các công ty công nghệ, vì họ không chắc chắn liệu dữ liệu của mình có bị các cơ quan chính phủ hoặc bên thứ ba giám sát hay không. Người dùng có thể hạn chế sử dụng dịch vụ đám mây và chuyển sang các lựa chọn khác với cam kết bảo mật cao hơn.
- **Gián đoạn hoạt động của doanh nghiệp:** Các doanh nghiệp sử dụng các dịch vụ bị ảnh hưởng bởi chương trình giám sát của NSA có thể gặp phải rủi ro lớn về bảo mật, làm giảm năng suất và uy tín của họ khi dữ liệu công ty bị truy cập trái phép.
- **Hậu quả:**
 - + **Ảnh hưởng đến quan hệ quốc tế:** Vụ rò rỉ làm rạn nứt mối quan hệ ngoại giao giữa Mỹ và các đồng minh, đặc biệt khi thông tin cho thấy NSA đã giám sát các nhà lãnh đạo nước ngoài, gây lo ngại về sự tin cậy trong quan hệ quốc tế.
 - + **Gia tăng lo ngại về quyền riêng tư và bảo mật:** Các quốc gia và tổ chức quốc tế bắt đầu thắt chặt các quy định về bảo mật và quyền riêng tư. Sự cố này dẫn đến các cuộc thảo luận về quyền riêng tư cá nhân, đẩy mạnh các phong trào bảo vệ dữ liệu cá nhân và yêu cầu các công ty công nghệ phải minh bạch hơn trong việc bảo vệ dữ liệu người dùng.

2.7. Rò rỉ dữ liệu từ dịch vụ đám mây

- Các vụ rò rỉ dữ liệu nghiêm trọng làm xói mòn niềm tin của người dùng vào khả năng bảo mật của dịch vụ đám mây. Lo ngại về việc dữ liệu nhạy cảm có thể bị lộ bất cứ lúc nào.
- Uy tín của nhà cung cấp dịch vụ bị tổn hại nghiêm trọng sau mỗi vụ rò rỉ. Điều này có thể dẫn đến việc mất khách hàng hiện tại và khó khăn trong việc thu hút khách hàng mới.
- Các vụ rò rỉ lớn có thể tạo ra tâm lý e ngại chung đối với việc sử dụng dịch vụ đám mây.
- Hậu quả:
 - + Nhà cung cấp dịch vụ: Phải đối mặt với các vụ kiện tụng từ khách hàng bị ảnh hưởng, các khoản phạt lớn từ các cơ quan quản lý về bảo vệ dữ liệu và các chi phí liên quan đến việc điều tra, khắc phục hậu quả và thông báo cho những người bị ảnh hưởng.
 - + Người dùng: Có thể phải chịu thiệt hại tài chính do thông tin cá nhân bị lạm dụng và mất mát dữ liệu kinh doanh quan trọng.

2.8. Đánh cắp tài khoản qua tấn công phishing

- Truy cập trái phép và chiếm đoạt dữ liệu:
 - + Người dùng: Khi tài khoản bị đánh cắp, kẻ tấn công có thể truy cập vào tất cả dữ liệu được lưu trữ trên dịch vụ đám mây của nạn nhân, bao gồm thông tin cá nhân, dữ liệu tài chính, bí mật kinh doanh, tài liệu quan trọng, v.v. Chúng có thể sao chép, xóa, sửa đổi hoặc sử dụng dữ liệu này cho các mục đích bất hợp pháp.
 - + Doanh nghiệp: Việc tài khoản nhân viên bị đánh cắp có thể dẫn đến lộ thông tin khách hàng, tài liệu nội bộ nhạy cảm, chiến lược kinh doanh, gây thiệt hại lớn về tài chính và uy tín.
- Lạm dụng tài nguyên đám mây:
 - + Phát tán thư rác (spam) hoặc phần mềm độc hại: Sử dụng tài khoản để gửi đi số lượng lớn email rác hoặc lây lan malware cho những người khác.
 - + Tấn công từ chối dịch vụ (DDoS): Sử dụng tài nguyên đám mây được cấp cho tài khoản bị đánh cắp để thực hiện các cuộc tấn công DDoS vào các mục tiêu khác.
 - + Đào tiền điện tử (cryptojacking): Lợi dụng sức mạnh tính toán của tài khoản để khai thác tiền điện tử mà không có sự cho phép của chủ sở hữu.

- + Lưu trữ và chia sẻ nội dung bất hợp pháp: Sử dụng không gian lưu trữ đám mây để chứa và phân phối các tài liệu vi phạm bản quyền, nội dung độc hại.
- **Tổn hại uy tín và lòng tin:**
 - + Người dùng: Nếu tài khoản của họ bị đánh cắp thông qua một lỗ hổng mà họ cho là do nhà cung cấp dịch vụ không đủ bảo mật, họ có thể mất niềm tin vào dịch vụ đó và chuyển sang các nhà cung cấp khác.
 - + Nhà cung cấp dịch vụ: Số lượng lớn các vụ đánh cắp tài khoản thành công có thể làm suy giảm nghiêm trọng uy tín của nhà cung cấp, khiến khách hàng lo ngại về khả năng bảo vệ tài khoản của họ.
- **Tăng chi phí khắc phục và phòng ngừa:**
 - + Nhà cung cấp dịch vụ: Phải đầu tư nhiều hơn vào các biện pháp bảo mật để phát hiện và ngăn chặn các cuộc tấn công phishing, cũng như xử lý các sự cố tài khoản bị đánh cắp (ví dụ: hỗ trợ người dùng khôi phục tài khoản, điều tra các hoạt động bất thường).
 - + Người dùng: Cũng cần đầu tư thời gian và nguồn lực để tăng cường nhận thức bảo mật cho bản thân và nhân viên, triển khai các biện pháp bảo vệ tài khoản (ví dụ: xác thực hai yếu tố), và xử lý các hậu quả nếu tài khoản bị xâm nhập.
- **Làm suy yếu các biện pháp bảo mật khác:**
 - + Một khi tài khoản đã bị đánh cắp, kẻ tấn công có thể vô hiệu hóa hoặc vượt qua các biện pháp bảo mật khác mà người dùng đã thiết lập (ví dụ: thay đổi số điện thoại hoặc email khôi phục, vô hiệu hóa xác thực hai yếu tố).
- **Tạo tiền đề cho các cuộc tấn công phức tạp hơn:**
 - + Tài khoản bị đánh cắp có thể được sử dụng làm bàn đạp để thực hiện các cuộc tấn công phức tạp hơn vào hệ thống đám mây hoặc các tài khoản khác trong cùng tổ chức.

2.9. Nhà cung cấp dịch vụ vi phạm quy định bảo vệ dữ liệu

- **Hậu quả pháp lý và tài chính nghiêm trọng:**
 - + Nhà cung cấp dịch vụ: Phải đối mặt với các vụ kiện tụng từ khách hàng bị ảnh hưởng, các khoản phạt khổng lồ từ các cơ quan quản lý về bảo vệ dữ liệu (ví dụ: GDPR, CCPA, các quy định tương

đương tại Việt Nam và các quốc gia khác). Các chi phí này có thể rất lớn, thậm chí đe dọa sự tồn tại của doanh nghiệp.

- + Khách hàng: Có thể bị phạt tiền bởi các cơ quan quản lý nếu dữ liệu khách hàng của họ (được lưu trữ trên nền tảng của nhà cung cấp vi phạm) bị lộ hoặc xử lý không đúng quy định. Họ cũng có thể phải chịu chi phí pháp lý và bồi thường cho các cá nhân bị ảnh hưởng.
- Mất lòng tin và suy giảm uy tín nghiêm trọng:
 - + Khách hàng: Khi nhà cung cấp dịch vụ không tuân thủ các quy định bảo vệ dữ liệu, khách hàng sẽ mất niềm tin vào khả năng bảo mật và quản lý dữ liệu của họ. Điều này dẫn đến việc họ có thể ngừng sử dụng dịch vụ và chuyển sang các nhà cung cấp khác đáng tin cậy hơn.
 - + Nhà cung cấp dịch vụ: Uy tín bị tổn hại nặng nề, gây khó khăn trong việc thu hút khách hàng mới và duy trì khách hàng hiện tại. Danh tiếng về bảo mật kém có thể kéo dài và rất khó khắc phục.

2.10. Tấn công từ chối dịch vụ phân tán

- Quá tải tài nguyên hệ thống: Các cuộc tấn công DDoS gây ra tình trạng quá tải băng thông và tài nguyên hệ thống, làm giảm hiệu năng của các dịch vụ mạng và ứng dụng trên hệ điều hành.
- Chi phí gia tăng và gián đoạn dịch vụ: Doanh nghiệp sẽ phải chi một khoản lớn để bảo vệ hệ thống khỏi DDoS và gia tăng các tài nguyên hạ tầng, điều này gây ảnh hưởng đến chi phí và khả năng mở rộng của hệ thống.

2.11. Ransomware & Malware

- Mất tính toàn vẹn của hệ thống: Một khi malware đã xâm nhập vào kernel và hệ thống tập tin của OS, việc phục hồi hệ thống có thể trở nên vô cùng khó khăn. Tính toàn vẹn của hệ thống sẽ bị phá vỡ, khiến việc duy trì các dịch vụ hoặc ứng dụng trở nên không ổn định.
- Gián đoạn dịch vụ: Khi dữ liệu của người dùng bị mã hóa hoặc thay đổi cấu hình hệ thống, các dịch vụ đám mây sẽ bị gián đoạn, gây ra thiệt hại về tài chính và uy tín đối với tổ chức cung cấp dịch vụ.

2.12. Social Engineering

- Phá vỡ mô hình bảo mật của OS: Một khi thông tin đăng nhập bị đánh cắp và quyền truy cập vào hệ thống bị lạm dụng, mô hình bảo mật của OS sẽ bị phá vỡ. Các biện pháp bảo mật như xác thực hai yếu tố và quyền truy cập theo nguyên tắc Least Privilege sẽ không còn hiệu quả.

- Giảm hiệu quả của giám sát và phát hiện tấn công: Thao túng thông tin đăng nhập có thể khiến hệ thống không thể phát hiện và phản ứng kịp thời với các hành vi bất thường, làm giảm khả năng bảo vệ của hệ điều hành.

CHƯƠNG 3: TRIỂN KHAI GIẢI PHÁP

1. Cách thức triển khai.

1.1. Giải pháp cho yếu tố “Lộ khóa API”

- Tuyệt đối không nhúng khóa API trực tiếp vào mã nguồn, file cấu hình tĩnh hoặc hệ thống quản lý phiên bản (VCS). Đây là nguyên tắc số một không thể bỏ qua.
- Ưu tiên sử dụng dịch vụ quản lý bí mật (Secrets Management Service) của nhà cung cấp đám mây (ví dụ: AWS Secrets Manager, Azure Key Vault, Google Cloud Secret Manager). Đây là cách an toàn và hiệu quả nhất để lưu trữ, quản lý và kiểm soát quyền truy cập vào khóa API và các bí mật khác. Các dịch vụ này cung cấp mã hóa, kiểm soát truy cập chi tiết, lịch sử phiên bản và khả năng xoay vòng bí mật tự động.
- Áp dụng nguyên tắc "Quyền tối thiểu" (Principle of Least Privilege) một cách nghiêm ngặt. Chỉ cấp quyền truy cập cần thiết cho từng khóa API và chỉ cho những thành phần hoặc dịch vụ thực sự cần.
- Tích hợp các công cụ quét bí mật (Secret Scanning Tools) vào quy trình phát triển phần mềm (CI/CD). Tự động phát hiện và ngăn chặn việc vô tình đưa khóa API vào mã nguồn hoặc hệ thống quản lý phiên bản.

1.2. Giải pháp cho yếu tố “Mất dữ liệu do lỗi kỹ thuật”

- Thiết lập chính sách phân quyền truy cập cho nhân viên, đảm bảo rằng chỉ những người cần thiết mới có quyền thay đổi cấu hình hệ thống hoặc thao tác với dữ liệu quan trọng.
- Sử dụng các giải pháp quản lý quyền truy cập (IAM) để hạn chế quyền truy cập và thực hiện kiểm tra và đánh giá định kỳ.
- Thiết lập các cảnh báo tự động nếu có hành động truy cập hoặc thay đổi không được phép.

1.3. Giải pháp cho yếu tố “Rò rỉ dữ liệu từ dịch vụ đám mây”

- Mã hóa dữ liệu nhạy cảm: Đảm bảo rằng dữ liệu quan trọng luôn được mã hóa ngay cả khi bị rò rỉ.

1.4. Giải pháp cho yếu tố “Tấn công từ chối dịch vụ phân tán”

- Tối ưu hóa tham số mạng của hệ điều hành: Điều chỉnh các tham số như backlog và time_wait để giảm thiểu ảnh hưởng của các cuộc tấn công SYN Flood.

- Sử dụng giải pháp chống DDoS: Triển khai các dịch vụ bảo vệ chống DDoS từ các nhà cung cấp như Cloudflare, AWS Shield, hoặc Azure DDoS Protection.
- Phân tán và cân bằng tải: Phân tán tài nguyên và sử dụng cân bằng tải (load balancer) để đảm bảo rằng hệ thống không bị quá tải tại một điểm duy nhất trong mạng.

2. Cách thức giải pháp giải quyết mối đe dọa.

2.1. Giải pháp cho yếu tố “Lộ khóa API”

- Không nhúng trực tiếp khóa API vào mã nguồn: Giải pháp này loại bỏ hoàn toàn nguy cơ khóa API bị lộ khi mã nguồn được chia sẻ, lưu trữ trong hệ thống quản lý phiên bản (VCS) hoặc bị tấn công.
- Sử dụng dịch vụ quản lý bí mật (Secrets Management Service):
 - + Lưu trữ an toàn: Các dịch vụ này mã hóa bí mật (bao gồm khóa API) khi lưu trữ và truyền tải, đảm bảo rằng ngay cả khi có truy cập trái phép vào hệ thống lưu trữ, khóa vẫn được bảo vệ.
 - + Kiểm soát truy cập chi tiết: Cho phép chỉ định rõ ràng những ứng dụng, dịch vụ hoặc người dùng nào được phép truy cập vào một bí mật cụ thể.
 - + Kiểm soát phiên bản và lịch sử: Theo dõi các thay đổi của bí mật và cho phép khôi phục các phiên bản trước đó nếu cần.
 - + Khả năng xoay vòng bí mật tự động: Tự động thay đổi khóa API theo lịch trình, giảm thiểu thời gian một khóa bị lộ có thể bị lợi dụng.
- Hạn chế quyền truy cập (Principle of Least Privilege): Chỉ cấp quyền cần thiết cho khóa API, ngăn chặn việc một khóa bị lộ có thể được sử dụng để thực hiện các hành động không được phép.
- Sử dụng các công cụ phát hiện bí mật (Secret Scanning Tools): Tự động hóa quá trình tìm kiếm bí mật trong mã nguồn, ngăn chặn việc chúng được đưa vào hệ thống quản lý phiên bản và có khả năng bị lộ.

2.2. Giải pháp cho yếu tố “Mất dữ liệu do lỗi kỹ thuật”

- Phân quyền truy cập hợp lý giúp giảm thiểu các lỗi do nhân viên hoặc người dùng không có đủ quyền hạn gây ra. Điều này giúp bảo vệ hệ thống khỏi thao tác sai và ngăn ngừa việc xóa dữ liệu quan trọng.

2.3. Giải pháp cho yếu tố “Rò rỉ dữ liệu từ dịch vụ đám mây”

- Bảo vệ dữ liệu khi lưu trữ (At Rest): Nếu dữ liệu nhạy cảm của khách hàng được mã hóa khi lưu trữ trong hệ thống, ngay cả khi kẻ

tấn công có quyền truy cập vào hệ thống (ví dụ như qua lỗ hổng SSRF), họ sẽ không thể đọc được dữ liệu vì thiếu khóa giải mã. Mã hóa khi lưu trữ sử dụng AWS KMS (Key Management Service) có thể giúp bảo vệ dữ liệu thể tin dụng, thông tin cá nhân và dữ liệu tài chính của khách hàng.

- Bảo vệ dữ liệu khi truyền tải (In Transit): Mã hóa khi truyền tải qua SSL/TLS giúp bảo vệ dữ liệu khỏi các cuộc tấn công man-in-the-middle (MITM). Mặc dù trong vụ Capital One, lỗ hổng SSRF không phải là một cuộc tấn công qua mạng, nhưng nếu dữ liệu được truyền tải qua các kết nối không mã hóa (HTTP thay vì HTTPS), nó có thể dễ dàng bị đánh cắp khi được truyền qua các kênh không bảo mật.
- Mã hóa Metadata và quyền truy cập: Trong vụ Capital One, kẻ tấn công đã khai thác quyền truy cập vào metadata EC2 của AWS để lấy được thông tin bảo mật nhạy cảm (ví dụ: IAM roles, API keys). Nếu metadata này được mã hóa hoặc quyền truy cập vào metadata được hạn chế nghiêm ngặt thông qua IAM roles, điều này có thể ngăn cản kẻ tấn công truy cập vào dữ liệu bảo mật.

2.4. Giải pháp cho yếu tố “Tấn công từ chối dịch vụ phân tán”

- Tối ưu hóa tham số mạng của hệ điều hành:
 - + Điều chỉnh backlog: Tăng kích thước hàng đợi backlog cho phép hệ thống lưu trữ nhiều kết nối SYN đang chờ hoàn thành hơn. Điều này giúp hệ thống có khả năng chịu đựng được một lượng lớn các gói SYN giả mạo trước khi bị quá tải.
 - + Điều chỉnh time_wait: Sau khi một kết nối TCP được đóng, nó sẽ chuyển sang trạng thái TIME_WAIT trong một khoảng thời gian nhất định để đảm bảo tất cả các gói tin đã được truyền tải. Trong các cuộc tấn công DDoS, việc có quá nhiều kết nối chuyển sang trạng thái TIME_WAIT có thể làm cạn kiệt tài nguyên. Việc điều chỉnh tham số này có thể giúp giải phóng tài nguyên nhanh hơn, nhưng cần cẩn thận để không gây ra các vấn đề liên quan đến việc truyền tải dữ liệu không hoàn chỉnh.
- Sử dụng giải pháp chống DDoS:
 - + Phân tích lưu lượng truy cập: Theo dõi và phân tích lưu lượng truy cập đến để phát hiện các mẫu bất thường và lưu lượng độc hại liên quan đến tấn công DDoS.

- + Lọc lưu lượng độc hại: Sử dụng các bộ lọc dựa trên nhiều tiêu chí (IP nguồn, địa lý, giao thức, hành vi) để chặn lưu lượng tấn công trước khi nó đến được hệ thống mục tiêu.
- + Giảm thiểu tấn công theo giao thức: Có các biện pháp cụ thể để đối phó với các loại tấn công DDoS phổ biến như SYN Flood, UDP Flood, HTTP Flood, DNS Amplification, v.v.
- + Hấp thụ lưu lượng tấn công (Traffic Scrubbing): Chuyển hướng lưu lượng truy cập đến các trung tâm dữ liệu của nhà cung cấp dịch vụ chống DDoS, nơi lưu lượng độc hại được lọc bỏ và chỉ lưu lượng hợp lệ được chuyển tiếp đến hệ thống mục tiêu.
- + Bảo vệ lớp ứng dụng: Phân tích các yêu cầu HTTP/HTTPS để phát hiện và ngăn chặn các cuộc tấn công nhắm vào lớp ứng dụng (ví dụ: HTTP Flood, Slowloris).
- Phân tán và cân bằng tải:
 - + Phân tán tài nguyên: Triển khai ứng dụng và dữ liệu trên nhiều máy chủ và ở nhiều khu vực khác nhau. Điều này làm cho việc tấn công thành công tất cả các tài nguyên cùng một lúc trở nên khó khăn hơn.
 - + Cân bằng tải (Load Balancer): Phân phối lưu lượng truy cập đến đều đặn trên nhiều máy chủ backend. Không một máy chủ nào bị dồn ép bởi toàn bộ lưu lượng truy cập, bao gồm cả lưu lượng tấn công. Nếu một hoặc một vài máy chủ bị ảnh hưởng bởi cuộc tấn công, bộ cân bằng tải có thể chuyển hướng lưu lượng đến các máy chủ khỏe mạnh khác, duy trì tính khả dụng của dịch vụ.

TÀI LIỆU THAM KHẢO

Khóa API là gì ?	https://aws.amazon.com/vi/what-is/api-key/
Tiềm ẩn nguy cơ an ninh mạng do API hardcode	https://locker.io/vi/blog/luu-api-hardcode
Twilio	https://techcrunch.com/?s=twilio
Capital One Data Breach – 2019	https://medium.com/nerd-for-tech/capital-one-data-breach-2019-f85a259eaa60
Google Docs Scams Still Pose a Threat	https://www.wired.com/story/google-docs-scams-threat-phishing/
The CNIL's restricted committee imposes a financial penalty of 50 Million euros against GOOGLE LLC	https://www.edpb.europa.eu/news/national-news/2019/cnils-restr
What Is SSRF?	https://www.f5.com/glossary/ssrf
Cloud Computing Explained	https://www.webopedia.com/reference/cloud-computing-guide/#:~:text=In%20cloud%20computing%2C%20the%20services,not%20the%20individual%20cloud%20customer
<i>The NIST Definition of Cloud Computing</i>	https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-145.pdf
<i>Microsoft finally explains cause of Azure breach: An engineer's account was hacked</i>	https://arstechnica.com/security/2023/09/hack-of-a-microsoft-corporate-account-led-to-azure-breach-by-chinese-hackers/
<i>The GitLab Database Incident</i>	https://lup.lub.lu.se/luur/download?func=downloadFile&recordId=8970730&fileId=8970733
<i>GitLab suffers major backup failure after data deletion incident</i>	https://techcrunch.com/2017/02/01/gitlab-suffers-major-backup-failure-after-data-deletion-incident/
<i>An INS Special Forum: Implications of the Snowden Leaks</i>	https://www.academia.edu/64902549/An_INS_Special_Forum_Implications_of_the_Snowden_Leaks